



Security Aspects in Industrial Areas

AQUASHIELD: WATER MONITORING SYSTEM

Semester Project Report

NAME: Arshathul Mohamed Haq ,Bahadur Ibrahim Khalifullah
Matriculation Number: 200494
Scope: Individual implementation contribution
Submission date: 15.07.2026

This report documents the author's individual contribution to a four-person industrial cybersecurity project. Components implemented by teammates are referenced only where required for integration context.

Contents

1. Project Implementation Scope	1
2. Implementation and Verification Methodology	1
3. System Architecture	3
3.1. Network Segmentation	3
3.2. Purdue Model Mapping	4
3.3. Addressing Plan	4
4. OT Firewall Configuration	5
5. PLC Simulator and Modbus TCP	6
5.1. Python PLC Simulator	6
5.2. Process Behaviour	7
6. FUXA HMI and SCADA Implementation	7
6.1. HMI Pages and Roles	7
6.2. Alarms, Historian, and Trends	7
7. Security Monitoring	8
7.1. Suricata IDS	8
7.2. Wazuh Agent and Alert Pipeline	9
8. MITRE ATT&CK for ICS Mapping	9
8.1. Technique Mapping	9
8.2. Attack Path Workflow	10
9. Security-Control Effectiveness and Risk Assessment	11
9.1. Qualitative Risk Matrix	11
9.2. Security-Control Effectiveness	12
9.3. Defence-in-Depth Analysis	12
10. Alignment with IEC 62443	13
10.1. Security Requirement Interpretation	13
10.2. Summary of Alignment	15
11. References	15

List of Figures

1.	Segmented network architecture for the virtual industrial water tank system. .	3
2.	Purdue model mapping of implemented and integrated project components. .	4
3.	Implemented OT pfSense firewall rule configuration.	5
4.	FUXA control, monitor, trend, and historian pages used for process operation and supervision.	8
5.	Suricata IDS rule and alert configuration for industrial protocol monitoring. . .	8
6.	Security monitoring workflow with Suricata deployed on the OT pfSense firewall at 10.21.2.1.	9
7.	Representative attack and detection workflow for unauthorised control activity in the virtual water tank environment.	11

List of Tables

1.	Verification methodology and expected versus observed results.	1
2.	Implemented addressing and service plan.	4
3.	PLC register mapping.	6
4.	FUXA pages and role access.	7
5.	MITRE ATT&CK for ICS techniques relevant to the implemented architecture. .	9
6.	Qualitative security risk matrix for the implemented system.	11
7.	Mapping of implemented components to IEC 62443 security requirements. .	14

1. Project Implementation Scope

The implemented work consisted of an operational technology environment for a virtual industrial water tank process. The contribution covered the OT network segmentation, OT pfSense firewall policy, Python-based PLC simulator, Modbus TCP communication, FUXA HMI and SCADA configuration, alarm management, SQLite historian, trends, role-based HMI pages, Wazuh agent deployment, Suricata IDS monitoring on the OT pfSense firewall at 10.21.2.1, Modbus and MQTT traffic detection, and the integration path through a reverse proxy.

The wider project was completed by four students. The IT firewall, MQTT broker, and external Internet network were implemented by teammates and are therefore discussed only where their interfaces affected the OT implementation. This report does not present the work as a thesis or a literature review. Instead, it documents the design decisions, configuration, security controls, and verification activities directly associated with the author's implementation.

2. Implementation and Verification Methodology

The project was verified using a scenario-based methodology rather than only by confirming that individual services were installed. Each test case started from an expected operational or security behaviour, exercised the relevant network path or HMI function, and then compared the observed result against screenshots, service status checks, firewall behaviour, process values, alarms, historian entries, Suricata alerts, or Wazuh events. This approach was suitable for the laboratory scope because the environment was virtual, deterministic, and repeatable.

Table 1: Verification methodology and expected versus observed results.

Test Area	Test Method	Expected Result	Observed Result	Outcome
Network segmentation	Attempted access only through the documented IT, DMZ, HMI, and PLC conduits.	Only explicitly allowed paths should pass through the OT firewall.	Required HTTP, FUXA, Modbus, and Wazuh paths were available; non-required cross-zone traffic was treated as blocked by policy.	Passed
Reverse proxy path	Accessed the FUXA interface through the DMZ reverse proxy route.	Users should reach FUXA without direct upstream access to the HMI host.	The HMI was reachable through the proxy integration path while the SCADA host remained behind the OT boundary.	Passed

Test Area	Test Method	Expected Result	Observed Result	Outcome
Modbus communication	Connected FUXA tags to the simulator register and coil map.	Tank level should be read from the holding register and commands should write to defined coils.	FUXA displayed tank state and issued pump, valve, automatic mode, and emergency-stop commands through Modbus TCP.	Passed
Role-based HMI access	Compared Admin and Analyst access to FUXA pages.	Admin should access control functions; Analyst should be limited to observation, alarms, trends, and historian review.	Control actions were placed on the Admin-only Water Control page, while monitoring views were available for observation roles.	Passed
Alarm behaviour	Drove the simulated process into low-level, high-level, and emergency-stop states.	Abnormal states should be visible to the operator through configured alarms.	FUXA alarm views represented high-level, low-level, and emergency-stop conditions.	Passed
Historian and trends	Changed tank state during normal operation and reviewed stored trend values.	Tank-level changes should be retained for later review.	SQLite-backed historian and trend views preserved process changes for operational evidence.	Passed
IDS detection	Generated Modbus and MQTT-related traffic across the monitored OT boundary.	Suricata should create protocol-relevant events in EVE JSON.	Custom Suricata rules produced alerts for Modbus TCP and MQTT traffic visible in the monitoring pipeline.	Passed
SIEM forwarding	Reviewed Wazuh collection of security-relevant log output.	Selected alerts and JSON events should be forwarded to the manager over allowed ports.	The Wazuh agent forwarded monitored events through the permitted 1514–1515 path.	Passed
Availability behaviour	Ran the PLC simulator as a managed service and checked restart-oriented deployment.	The simulator should be easier to recover after service interruption or host reboot.	The simulator was deployed with <code>systemd</code> restart behaviour for improved laboratory availability.	Passed

The main evaluation limitation is that the tests demonstrate functional and security-control behaviour in a controlled virtual environment. They do not prove resistance against a complete attacker campaign, do not certify IEC 62443 compliance, and do not replace penetration testing on production industrial equipment. Nevertheless, the tests provide traceable evidence that the implemented components worked together as a segmented SCADA monitoring environment.

3. System Architecture

3.1. Network Segmentation

The architecture was organised as a segmented industrial environment rather than as a flat laboratory network. The OT firewall was placed between the IT network and the industrial zones, and explicit allow rules were used for required flows. This structure supported a practical interpretation of zone and conduit principles described in industrial security guidance such as IEC 62443, NIST SP 800-82, and CISA guidance [1], [2], [3].

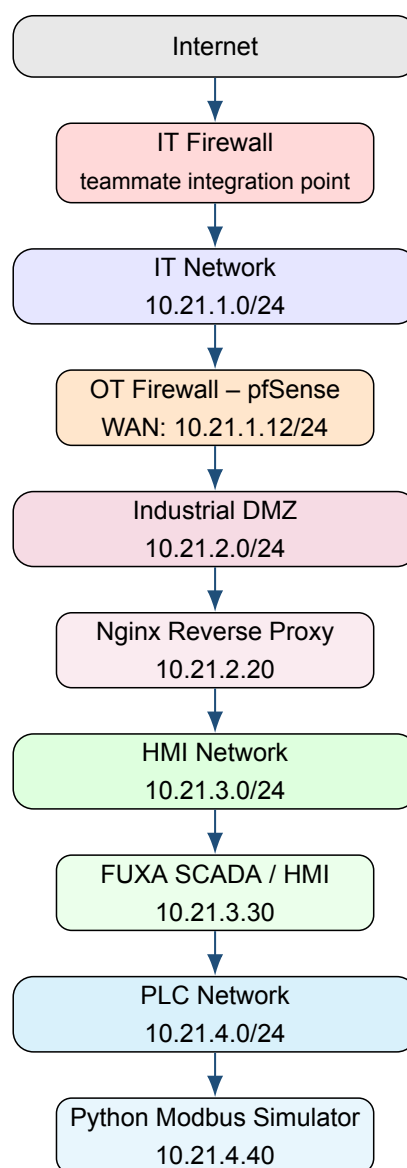


Figure 1: Segmented network architecture for the virtual industrial water tank system.

The OT firewall separated the industrial DMZ, HMI network, and PLC network. Only the required application conduits were permitted: HTTP access to the reverse proxy, reverse

proxy access to FUXA, Modbus communication from FUXA to the simulator, and Wazuh agent forwarding from the SCADA host to the SIEM endpoint.

3.2. Purdue Model Mapping

The project components were mapped to the Purdue Enterprise Reference Architecture to clarify their operational role. The mapping is not intended to claim a complete enterprise deployment; it records how the virtual environment was structured for the course project.

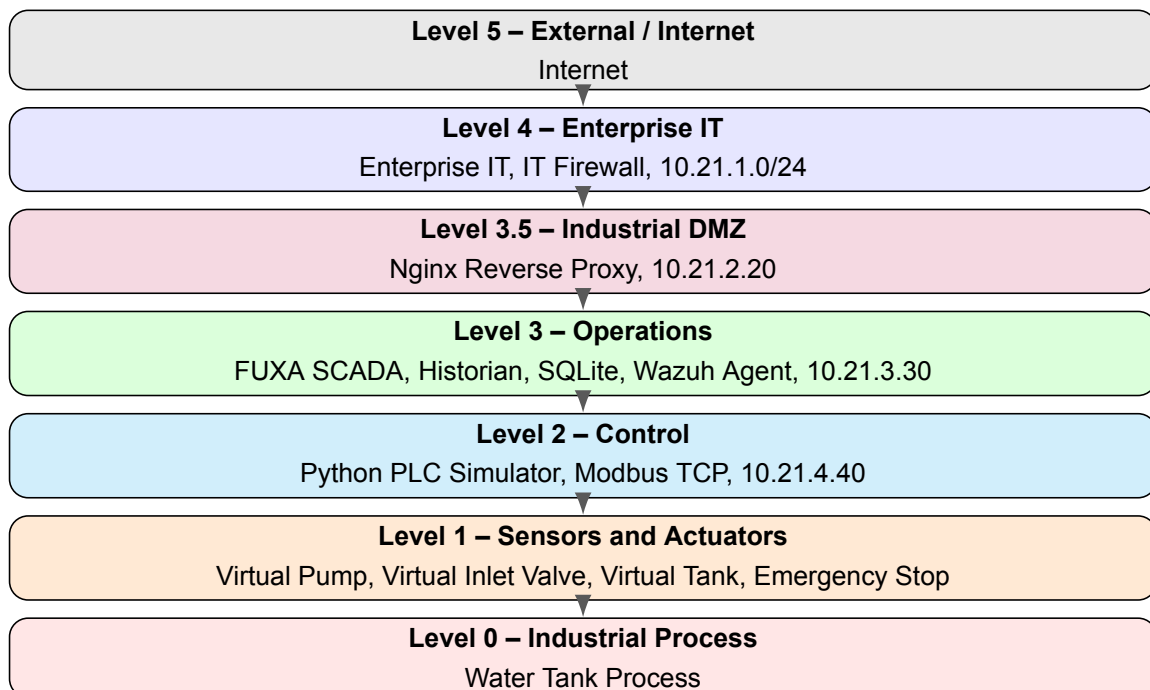


Figure 2: Purdue model mapping of implemented and integrated project components.

3.3. Addressing Plan

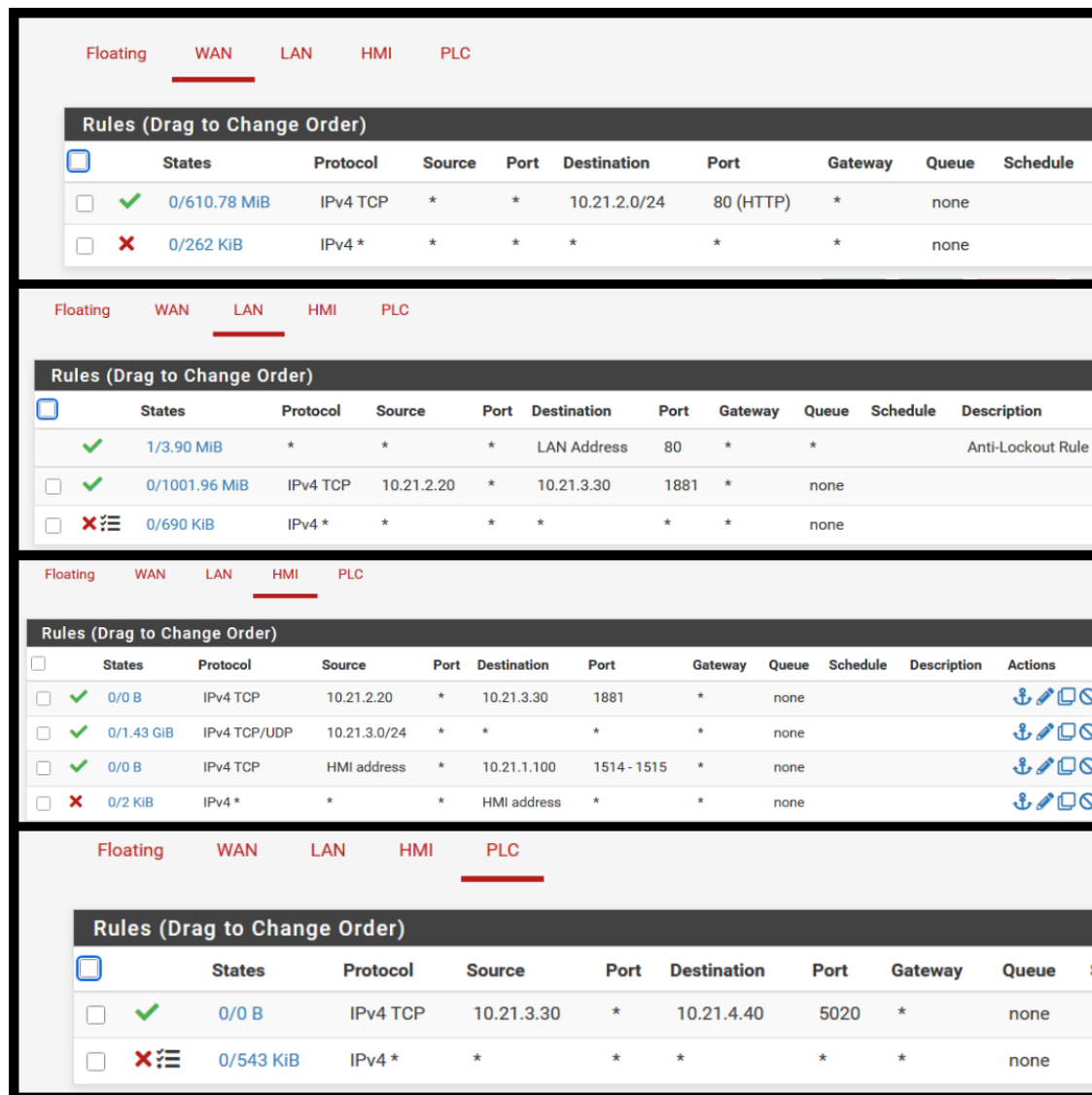
Table 2: Implemented addressing and service plan.

Device	Role	IP Address	Subnet	Gateway	Service / Port
IT Firewall	Upstream boundary	10.21.1.1	10.21.1.0/24	External	Routing / filtering
OT Firewall	WAN interface	10.21.1.12	10.21.1.0/24	10.21.1.1	pfSense
OT Firewall	IDMZ gateway	10.21.2.1	10.21.2.0/24	–	Firewall gateway
OT Firewall	HMI gateway	10.21.3.1	10.21.3.0/24	–	Firewall gateway
OT Firewall	PLC gateway	10.21.4.1	10.21.4.0/24	–	Firewall gateway
Nginx Reverse Proxy	DMZ access point	10.21.2.20	10.21.2.0/24	10.21.2.1	HTTP / 80
FUXA SCADA	HMI and historian	10.21.3.30	10.21.3.0/24	10.21.3.1	FUXA / 1881
Python PLC Simulator	Virtual controller	10.21.4.40	10.21.4.0/24	10.21.4.1	Modbus TCP / 5020

Device	Role	IP Address	Subnet	Gateway	Service / Port
Wazuh Manager	SIEM endpoint	10.21.1.100	10.21.1.0/24	10.21.1.1	Agent / 1514–1515
MQTT Broker	Message broker	Team component	IT/DMZ path	Team gateway	MQTT / 1883

4. OT Firewall Configuration

The pfSense firewall was configured as the primary OT boundary control. Rules were written as default-deny policies for each interface, with explicit permits for the communications required by the implementation. This approach reduced unnecessary lateral movement paths and made the permitted industrial conduits visible during testing.



The figure displays four screenshots of the pfSense firewall rule configuration interface, showing rules for different network interfaces: WAN, LAN, HMI, and PLC.

WAN Interface Rules:

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule
0/610.78 MiB	IPv4 TCP	*	*	10.21.2.0/24	80 (HTTP)	*	none	
0/262 KiB	IPv4 *	*	*	*	*	*	none	

LAN Interface Rules:

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description
1/3.90 MiB	*	*	*	LAN Address	80	*	*		Anti-Lockout Rule
0/1001.96 MiB	IPv4 TCP	10.21.2.20	*	10.21.3.30	1881	*	none		
0/690 KiB	IPv4 *	*	*	*	*	*	none		

HMI Interface Rules:

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
0/0 B	IPv4 TCP	10.21.2.20	*	10.21.3.30	1881	*	none			
0/1.43 GiB	IPv4 TCP/UDP	10.21.3.0/24	*	*	*	*	none			
0/0 B	IPv4 TCP	HMI address	*	10.21.1.100	1514 - 1515	*	none			
0/2 KiB	IPv4 *	*	*	HMI address	*	*	none			

PLC Interface Rules:

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule
0/0 B	IPv4 TCP	10.21.3.30	*	10.21.4.40	5020	*	none	
0/543 KiB	IPv4 *	*	*	*	*	*	none	

Figure 3: Implemented OT pfSense firewall rule configuration.

The firewall screenshot documents the implemented rule base for the OT boundary. The WAN, industrial DMZ, and HMI rule sets were configured to permit only the required conduits: HTTP access into the DMZ reverse proxy path, reverse proxy communication to FUXA on port 1881, Modbus TCP communication from FUXA to the PLC simulator on port 5020, and Wazuh agent forwarding to the SIEM endpoint on ports 1514–1515. This control does more than block traffic: it enforces separation between enterprise-facing access paths and industrial control assets, reducing lateral movement opportunities while making every permitted cross-zone flow explicit and reviewable. The remaining risk is that any allowed conduit, especially web access to FUXA or Modbus traffic from FUXA to the simulator, must be monitored because firewall policy cannot validate the intent of an authorised application request.

5. PLC Simulator and Modbus TCP

5.1. Python PLC Simulator

The PLC was implemented as a Python service using `pymodbus`. The simulator used host 10.21.4.40 and port 5020. This avoided the requirement for privileged access to TCP port 502 while preserving Modbus TCP semantics. The simulator exposed a small but sufficient process model: tank level, pump command, inlet valve command, automatic mode, and emergency stop.

The simulator was configured to run as a `systemd` service so that the virtual controller could restart automatically after host reboot or service failure. The implementation was deliberately limited to the functions required by the project; it was not presented as a production PLC runtime.

Table 3: PLC register mapping.

Type	Address	Tag	Data Type	Description
Holding Register	40001	<code>tank_level</code>	Integer	Virtual water tank level represented as a percentage.
Coil	00001	<code>pump</code>	Boolean	Pump command used to increase the simulated tank level.
Coil	00002	<code>valve</code>	Boolean	Inlet or outlet valve state used by the process logic.
Coil	00003	<code>automatic</code>	Boolean	Automatic control mode flag.
Coil	00004	<code>emergency_stop</code>	Boolean	Safety stop that overrides normal commands.

Only essential implementation fragments are shown. The full simulator code is not reproduced because the report concerns implementation and assessment rather than source-code publication.

5.2. Process Behaviour

The process model was intentionally deterministic. During normal operation, the pump and valve commands changed the tank level within bounded limits. The emergency stop coil was treated as a higher-priority command and was used to suppress normal control behavior. This allowed the HMI, alarm, historian, IDS, and SIEM functions to be tested without claiming physical validation on real industrial equipment.

6. FUXA HMI and SCADA Implementation

FUXA was deployed on the HMI network at 10.21.3.30 and exposed on port 1881. It was configured as both the HMI and SCADA component for the project. Its Modbus driver was used to read the holding register for tank level and to write the coils used for pump, valve, automatic mode, and emergency stop commands.

6.1. HMI Pages and Roles

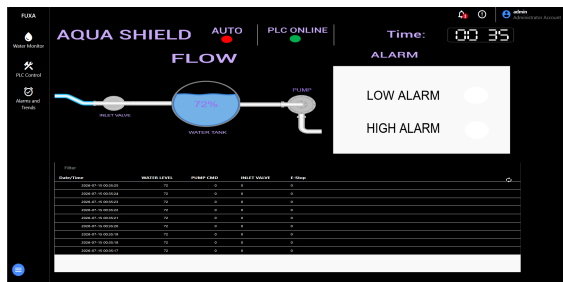
Two roles were configured. The *Admin* role was allowed to operate the process and access administrative views. The *Analyst* role was restricted to monitoring, alarm review, and trend analysis. This role separation reduced the likelihood that a monitoring user could accidentally perform control actions.

Table 4: FUXA pages and role access.

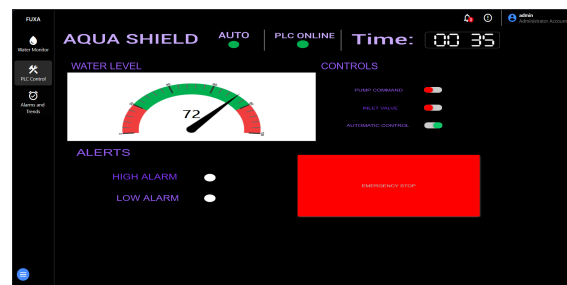
Page	Purpose	Role Access
Water Control	Pump, valve, automatic mode, emergency stop	Admin only
Water Monitor	Tank state and process indicators	Admin and Analyst
Alarm & Trends	Alarm list and trend graphs	Admin and Analyst
Historian	SQLite-backed historical data review	Admin and Analyst

6.2. Alarms, Historian, and Trends

Alarm management was configured around process states that were meaningful for a virtual tank: high level, low level, and emergency stop active. The historian used SQLite to store time-series values and event states. Trend graphs were then used to review tank-level changes during normal operation, pump start, high alarm, and emergency-stop scenarios.



(a) FUXA monitor and alarm view.



(b) FUXA Water Control page used for process operation.



(c) FUXA trend and historian view.

Figure 4: FUXA control, monitor, trend, and historian pages used for process operation and supervision.

7. Security Monitoring

7.1. Suricata IDS

Suricata was installed on the OT pfSense firewall at 10.21.2.1 and was used to monitor industrial protocol traffic crossing the OT boundary. It produced structured EVE JSON events [4]. The implemented detection focused on Modbus communication between FUXA and the Python PLC simulator, and MQTT traffic associated with the integrated broker path. Placing Suricata on pfSense allowed inspection close to the routed OT conduits rather than only on an endpoint host.

```
alert tcp !10.21.3.30 any -> 10.21.4.40 5020
(msg: "OT unauthorized Modbus access to PLC"; flow:to_server, established; sid:9002101;rev:1;)
```

Figure 5: Suricata IDS rule and alert configuration for industrial protocol monitoring.

7.2. Wazuh Agent and Alert Pipeline

The Wazuh agent was installed on the SCADA host and configured to forward relevant host logs to the Wazuh manager on 10.21.1.100 using ports 1514--1515 [5]. Suricata EVE JSON records generated on the pfSense firewall at 10.21.2.1 were treated as the network IDS source for Modbus and MQTT visibility, while Wazuh provided central review of collected security events.



Figure 6: Security monitoring workflow with Suricata deployed on the OT pfSense firewall at 10.21.2.1.

The monitoring design provided visibility into network events while retaining separation between control traffic and monitoring output. JSON parsing was preferred because it preserved useful fields such as source address, destination address, destination port, signature identifier, and alert message.

8. MITRE ATT&CK for ICS Mapping

The most relevant attack paths involve exposed HMI access, unauthorised Modbus commands, lateral movement across weakly separated zones, abuse of remote services, manipulation of process values, and interruption of control or monitoring services. These techniques were selected because the project includes a reverse proxy, FUXA SCADA service, Modbus TCP simulator, historian, Suricata IDS on the pfSense firewall, Wazuh log forwarding, and segmented OT firewall rules.

8.1. Technique Mapping

Table 5: MITRE ATT&CK for ICS techniques relevant to the implemented architecture.

Technique ID	Technique Name	Possible Attack	Detection Method	Mitigation
T0855	Unauthorized Command Message	An attacker who reaches the allowed control path attempts unauthorised Modbus coil writes for pump, valve, automatic mode, or emergency stop.	Suricata Modbus alerts, FUXA alarm states, historian trends, and unexpected process transitions.	Permit Modbus only from FUXA to the simulator, block all other sources at the OT firewall, and review write activity.

Technique ID	Technique Name	Possible Attack	Detection Method	Mitigation
T0831	Manipulation of Control	An attacker abuses HMI access or Modbus commands to change the virtual water tank behaviour.	Correlate FUXA control actions with alarm records, historian values, and IDS observations of Modbus traffic.	Restrict Water Control to Admin users and retain historian evidence for post-event review.
T0842	Network Service Scanning	An attacker scans the DMZ, HMI, or PLC network to identify FUXA, Modbus, Wazuh, or proxy services.	pfSense denies, Suricata scan signatures, and abnormal connection patterns in logs.	Maintain default-deny segmentation and expose only required ports between zones.
T0812	Default Credentials	An attacker attempts common or weak credentials against FUXA or supporting web access.	Wazuh host logs, reverse proxy access logs, and repeated authentication failures where available.	Use role separation, remove default accounts, enforce strong passwords, and limit administrative access.
T0803	Block Reporting Message	An attacker disrupts alarms, Suricata EVE JSON generation, or Wazuh forwarding to hide activity.	Missing Wazuh events, gaps in EVE JSON, absent historian samples, or service-health anomalies.	Allow Wazuh ports only where needed, retain local logs, and monitor agent and IDS service status.
T0828	Loss of View	An attacker interferes with FUXA monitoring, historian updates, or displayed process state.	Compare HMI values with historian records, alarm history, and expected Modbus polling behaviour.	Preserve historian data, limit HMI administration, and monitor SCADA host availability.
T0814	Denial of Service	An attacker overloads FUXA, the simulator service, or permitted network conduits.	Service status checks, missing telemetry, Suricata alerts, and Wazuh availability events.	Keep unnecessary services closed, use managed services, and monitor critical OT components.
T0882	Theft of Operational Information	An attacker gathers IP addressing, HMI pages, register mappings, or historian data to prepare later manipulation.	Reverse proxy logs, Wazuh file or access events, and unexpected access to SCADA/historian resources.	Limit user privileges, restrict direct host access, and protect configuration and historian files.

The mapping shows that the project is most exposed to attacks that abuse allowed conduits rather than attacks that require broad network access. The principal defensive value therefore comes from narrowing allowed communication paths, monitoring industrial protocol activity, preserving historian evidence, and forwarding security events to Wazuh. The implementation uses MITRE ATT&CK for ICS as a structured analysis aid rather than as evidence of a full adversary emulation exercise [6].

8.2. Attack Path Workflow

The workflow in Fig. 7 illustrates a realistic misuse case without claiming that a successful compromise was performed. The attacker first targets the exposed access path, then at-

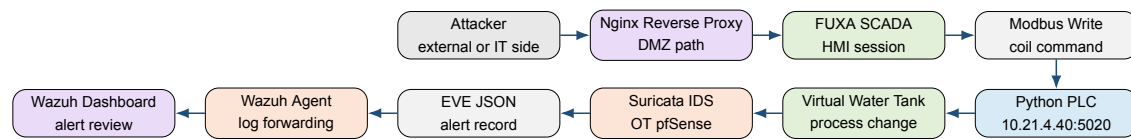


Figure 7: Representative attack and detection workflow for unauthorised control activity in the virtual water tank environment.

tempts to reach the SCADA layer and issue a control action that becomes a Modbus write toward the simulator. The industrial impact would be visible as a process change or alarm in FUXA. Detection depends on multiple evidence sources: Suricata observes protocol activity at the OT boundary, EVE JSON preserves structured alert fields, and the Wazuh agent forwards events for central review. This chain demonstrates defence value because no single component is treated as sufficient on its own.

9. Security-Control Effectiveness and Risk Assessment

The implemented controls reduced the most important risks for the virtual water tank environment by limiting reachable services, separating duties in the HMI, monitoring industrial protocol activity, and forwarding relevant events to a central SIEM workflow. The assessment below focuses on residual risk after implementation rather than on theoretical risk in an unprotected flat network.

9.1. Qualitative Risk Matrix

Table 6: Qualitative security risk matrix for the implemented system.

Threat	Affected Asset	Likelihood	Impact	Risk Level	Mitigation
Unauthorized Modbus Write	PLC simulator and virtual process	Medium	High	High	Restrict Modbus to FUXA-to-PLC traffic, alert on Modbus writes, and review historian/alarm correlation.
Unencrypted MQTT Traffic	Broker integration path and monitoring visibility	Medium	Medium	Medium	Monitor MQTT traffic with Suricata and treat broker hardening as a required team-side improvement.
Unauthorized SCADA Login	FUXA HMI and control pages	Medium	High	High	Enforce strong credentials, remove default accounts, and keep control functions limited to Admin users.
Reverse Proxy Misconfiguration	DMZ access path and FUXA exposure	Medium	High	High	Limit upstream exposure, review Nginx forwarding rules, and add TLS/access hardening as future work.

Threat	Affected Asset	Likelihood	Impact	Risk Level	Mitigation
Denial of Service against PLC	Python Modbus simulator and FUXA telemetry	Low to medium	High	Medium	Use firewall restrictions, managed service restart behaviour, and monitor missing telemetry or service outages.
Historian Tampering	SQLite historian and trend evidence	Low to medium	Medium	Medium	Limit host access, monitor file changes, and introduce protected backups where required.
Blocked Event Forwarding	Suricata, EVE JSON, and Wazuh pipeline	Medium	Medium	Medium	Retain local logs, monitor Wazuh agent health, and alert on gaps in expected event flow.

9.2. Security-Control Effectiveness

The risk matrix indicates that the highest residual risks are not caused by a lack of segmentation, but by the trust placed in allowed application flows. A source-restricted Modbus conduit is necessary, yet it cannot provide command authentication because Modbus TCP does not include native cryptographic protection. Similarly, the reverse proxy reduces direct SCADA exposure but does not by itself guarantee secure user authentication or TLS hardening. The most effective implemented controls are therefore compensating controls: least-privilege firewall rules, role-based HMI separation, historian evidence, Suricata protocol visibility, and Wazuh event forwarding.

Overall, the strongest controls were restricted data flow, role-based separation of control and monitoring, and boundary visibility through Suricata and Wazuh. The highest residual risks remained around protocol trust and application hardening: Modbus TCP does not authenticate commands, the reverse proxy path was not presented as TLS-hardened, and the laboratory simulator cannot represent all failure modes of a physical controller. These gaps are acceptable for the course implementation scope but should be addressed before transferring the design to a production-like industrial environment.

9.3. Defence-in-Depth Analysis

The architecture implements defence in depth by distributing security functions across network, application, monitoring, and evidence layers instead of relying on a single control. The Internet and IT firewall form the upstream boundary, but the report does not assume that this boundary is sufficient for OT protection. The OT pfSense firewall provides the most important segmentation control by separating the industrial DMZ, HMI network, and PLC network, thereby reducing direct reachability of the simulator and SCADA host. The industrial DMZ and Nginx reverse proxy provide an additional buffer between upstream access and FUXA,

limiting direct exposure of the HMI service.

At the application layer, FUXA role-based access control separates process operation from monitoring and trend review. This does not provide protocol-level security for Modbus TCP, but it reduces accidental or unauthorised use of HMI control functions by non-operational users. Suricata adds a network detection layer by inspecting relevant Modbus and MQTT traffic at the OT boundary, while Wazuh adds centralised event review for selected host and IDS outputs. The SQLite historian provides a process-evidence layer: even when an event is not immediately recognised as malicious, trend and alarm records can support later analysis of process behaviour.

The remaining weaknesses are typical for a laboratory OT implementation. Modbus TCP remains unauthenticated and unencrypted, MQTT broker hardening was outside the individual implementation scope, and the reverse proxy was not presented as certificate-hardened. The defence-in-depth value therefore lies in containment, visibility, and evidence preservation rather than in complete prevention of every misuse case.

10. Alignment with IEC 62443

IEC 62443 was used as the main reference point for evaluating whether the implemented OT environment followed recognised industrial cybersecurity principles. The project was not certified against IEC 62443, and no formal security level assessment was performed. Instead, the implemented components were mapped to relevant IEC 62443-3-3 security requirements, with emphasis on identification and authentication control, use control, system integrity, restricted data flow, timely response to events, and resource availability [1], [7].

10.1. Security Requirement Interpretation

The implemented architecture primarily supported IEC 62443 through segmentation, least-privilege communication, role separation, protocol monitoring, and event forwarding. The OT firewall and network layout addressed restricted data flow by separating the IT network, industrial DMZ, HMI network, and PLC network. FUXA user roles addressed use control by separating administrative control functions from monitoring functions. Suricata on the OT pfSense firewall and Wazuh supported timely response to events by collecting security-relevant observations from Modbus and MQTT traffic and centralising event review. The Python PLC simulator, historian, alarm configuration, and systemd deployment supported controlled operation and repeatable service behaviour within the laboratory environment.

The mapping is intentionally limited to the components that were implemented by the author. Team components, including the IT firewall, MQTT broker, and external Internet network,

are included only where they form an integration boundary with the implemented OT environment.

Table 7: Mapping of implemented components to IEC 62443 security requirements.

Project Component	IEC 62443 Security Requirement	Implementation	Security Benefit
OT firewall and network segmentation	SR 5.1 – Network segmentation; SR 5.2 – Zone boundary protection	IT, industrial DMZ, HMI, and PLC networks were separated and routed through pfSense with explicit allow rules.	Reduces lateral movement and prevents direct reachability of PLC and HMI assets from upstream networks.
Industrial DMZ and Nginx reverse proxy	SR 5.2 – Zone boundary protection; SR 7.1 – Resource availability	Upstream access was routed through a DMZ reverse proxy instead of exposing FUXA directly.	Creates a controlled access point and limits direct exposure of the SCADA service, although TLS hardening remains future work.
FUXA user roles	SR 1.1 – Human user identification and authentication; SR 2.1 – Authorization enforcement	Admin users were allowed to operate Water Control, while Analyst users were limited to monitoring, alarms, trends, and historian review.	Separates control from observation and reduces accidental or unauthorised process operation.
FUXA HMI pages	SR 2.1 – Authorization enforcement; SR 7.6 – Least functionality	Control functions were isolated on the Admin-only page; monitoring functions were separated into observation and review pages.	Limits the operational effect of non-control users and makes process functions easier to audit.
Python Modbus simulator	SR 3.1 – Communication integrity; SR 7.1 – Availability	The simulator exposed a defined register and coil map and was deployed as a managed service.	Provides repeatable control behaviour for testing and improves recovery after service interruption.
Modbus TCP conduit	SR 5.2 – Zone boundary protection; SR 3.1 – Communication integrity	Modbus TCP was restricted to the FUXA-to-PLC path on port 5020.	Reduces the attack surface for unauthorised command messages, while leaving residual risk because Modbus TCP itself is not authenticated or encrypted.
Alarm management	SR 6.1 – Audit log accessibility; SR 7.1 – Availability	High-level, low-level, and emergency-stop conditions were configured in FUXA.	Supports timely operator awareness of abnormal process states and provides operational context for security review.
SQLite historian	SR 6.1 – Audit log accessibility; SR 6.2 – Continuous monitoring support	Tank level and event states were stored and visualised through historian and trend views.	Preserves process evidence for post-event analysis, although file protection and backups remain future improvements.
Suricata IDS	SR 3.2 – Malicious code protection; SR 6.2 – Continuous monitoring support	Suricata on pfSense generated EVE JSON alerts for Modbus TCP and MQTT-related traffic.	Provides boundary visibility into industrial protocol activity and supports detection of suspicious command or reconnaissance behaviour.
Wazuh agent and manager path	SR 6.1 – Audit log accessibility; SR 6.2 – Continuous monitoring support	The Wazuh agent forwarded selected events to the manager using allowed ports 1514–1515.	Centralises review of security-relevant logs and supports correlation with IDS and host observations.
MQTT monitoring integration	SR 6.2 – Continuous monitoring support	MQTT traffic associated with the integrated broker path was monitored by Suricata, while broker hardening remained outside the individual scope.	Adds visibility to broker-related traffic without overstating control over the teammate-implemented broker.

10.2. Summary of Alignment

The strongest alignment was achieved in restricted data flow, use control, event visibility, and operational availability. The firewall policy and network design directly supported the IEC 62443 expectation that industrial systems should be divided into zones and connected through controlled conduits. The FUXA role model provided a practical separation between control and monitoring functions. Suricata on pfSense improved OT boundary visibility, while Wazuh supported central review of collected security events.

The main limitations were also clear. Modbus TCP does not provide native encryption or strong authentication, and the project did not implement certificate-based access control for the reverse proxy. The PLC was a simulator, so the alignment relates to the virtual implementation rather than a certified industrial controller. These limitations do not invalidate the project, but they define the boundary of the IEC 62443 mapping.

11. References

- [1] "Iec 62443 series: Industrial communication networks – network and system security," International Electrotechnical Commission, Accessed: Jul. 15, 2026. [Online]. Available: <https://www.iec.ch/cyber-security>
- [2] K. Stouffer, V. Pillitteri, S. Lightman, M. Abrams, A. Hahn, and M. Pease, "Guide to operational technology security," National Institute of Standards and Technology, Tech. Rep. SP 800-82 Rev. 3, 2024. DOI: 10.6028/NIST.SP.800-82r3 Accessed: Jul. 15, 2026. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-82r3>
- [3] "Industrial control systems recommended practices," Cybersecurity and Infrastructure Security Agency, Accessed: Jul. 15, 2026. [Online]. Available: <https://www.cisa.gov/resources-tools/resources/ics-recommended-practices>
- [4] "Suricata user guide," Open Information Security Foundation, Accessed: Jul. 15, 2026. [Online]. Available: <https://docs.suricata.io/>
- [5] "Wazuh documentation," Wazuh Inc., Accessed: Jul. 15, 2026. [Online]. Available: <https://documentation.wazuh.com/>
- [6] "Mitre att&ck for ics matrix," MITRE, Accessed: Jul. 15, 2026. [Online]. Available: <https://attack.mitre.org/matrices/ics/>
- [7] *Iec 62443-3-3: Industrial communication networks – network and system security – part 3-3: System security requirements and security levels*, International Electrotechnical Commission, 2013. Accessed: Jul. 15, 2026. [Online]. Available: <https://webstore.iec.ch/publication/7033>